

RESEARCH ARTICLE

Reconfiguring Role-Based Access Control via Role Clustering

OSMAN DURDAG¹ AND AHMET COSKUNCAY²¹Department of Software Engineering, Atatürk University, 25240 Erzurum, Türkiye²Department of Computer Engineering, Atatürk University, 25240 Erzurum, Türkiye

Corresponding author: Osman Durdag (osmandurdag@atauni.edu.tr)

ABSTRACT Role-based access control (RBAC) systems have become a widely used and accepted method by many organizations today due to their efficiency and ease of management. However, to truly benefit from RBAC systems, the roles in the relevant system must be well defined. Bottom-up, top-down, and hybrid approaches exist to accurately define the roles to be included in access control systems. Even if RBAC systems are designed carefully, the role privilege assignments tend to wear out and become chaotic after some time. This study demonstrates a role mining approach to reconfiguring such existing client specific RBAC systems by identifying clusters of similar roles using the assigned privileges. In this study, masked RBAC data of 10 clients of a software company are used. The approach creates role clusters via Agglomerative Hierarchical Clustering, an unsupervised clustering algorithm that works in a bottom-up technique. The experiment results show that it is better using the resulting candidate clusters as a reference in reconfiguring the RBAC systems, instead of using them to replace the existing roles. Additionally, it has been observed that in some client tables with a limited number of unique roles, the pairwise F1 score was remarkably high, indicating a strong correspondence between the candidate and expected roles.

INDEX TERMS Agglomerative hierarchical clustering, pairwise evaluation, role-based access control, role mining.

I. INTRODUCTION

Role-based access control (RBAC) systems offer an easy-to-manage and efficient access control method [1] that many organizations widely use to ensure system security today [2]. In role-based access control systems, associating users with the functions or privileges they will have, is carried out through the roles defined in the system [3]. In the conventional method, the privileges are assigned to the users one by one, and the tables storing privileges are used to record these associations. In RBAC systems, the organization's functions or system are defined by roles, and the users are associated with these roles. That is the privileges assignments following two successive steps.

In RBAC systems, the role count is less than the user count, so the complexity level compared to the conventional method is significantly less which simplifies management.

The associate editor coordinating the review of this manuscript and approving it for publication was Qilian Liang.

According to a NIST report [4], RBAC systems can save time for various management functions. By defining the roles within business units or specific sets of operations, roles provide well management of the confusion that can arise if a user leaves the system or changes units. Instead of deleting or changing the users' privileges, the relationship between the users and the associated roles is disconnected or the users are associated with different roles. The importance and utility of RBAC systems are apparent and understood when they are implemented in large systems or organizations. Many companies and systems use it today due to its utility and manageability [5].

The role engineering process, which defines the roles ultimately, accurately, and efficiently, is seen as an essential requirement for the RBAC system's benefit to emerge [6]. Creating the RBAC structure which includes identifying the roles and assigning privileges to these roles, is defined as role engineering [7]. According to a NIST study, applying the role engineering process to the RBAC system has an

iterative nature and is one of the costliest components of system design [4]. The fact that role engineering is time-consuming and expensive work pushes organizations that currently perform an access control system with the conventional method to be hesitant about transitioning to the RBAC system.

Two main approaches have been proposed to develop RBAC systems [8]. A top-down RBAC system configuration begins with a thorough analysis of business processes, continues with the creation of roles corresponding to various business units, and culminates in the assignment of permissions to these roles. This top-down approach is referred to as role engineering [9]. However, this operation will be challenging and time-consuming for large systems that includes many users, work units, and permissions. The bottom-up approach, referred to as role mining, systematically identifies roles through data mining algorithms based on the privileges defined in the traditional system currently in use [9]. The bottom-up approach has an advantage when it comes to automating the creation of the RBAC system. However, if the existing user-privilege tables do not include meaningful data about business units, then the operation will not produce the expected results. A hybrid approach that combines these two approaches may also be used to create RBAC systems [10].

RBAC's efficiency has been widely accepted and used by many organizations over the years. On the other hand, in many cases, in large-scale companies with huge numbers of users or business units, business requirements are constantly changing as well as the complexity of processing and storing large amounts of data is increasing [11]. These situations are also reflected in access control systems so that even if the RBAC structure is used, it makes the management of the system difficult. RBAC systems enlarge as new users or business units are added to or deleted from the system. Administrators can define new roles for each new user or privilege. They can also create a role for each new job position without considering whether users sharing the same job position will be subject to the same privileges [12]. In such cases, legacy roles (i.e. roles without users assigned) may also arise when the users leave the organization or change job positions. Top management can also interfere in RBAC system design by mandating permission changes or new role creations, thus causing to lose control of RBAC administrators over the system [13]. Such enlargements of the RBAC system cause it to wear out and become chaotic. Reconfiguring the current RBAC systems is as costly as designing a new RBAC system [12].

In today's rapidly changing enterprise environments, adapting Role-Based Access Control systems to meet the evolving requirements of user roles and permissions presents a significant challenge. Numerous studies have explored algorithmic solutions to streamline RBAC reconfiguration with minimal adjustments and cost implications. For instance, Pan et al. introduced a hierarchical RBAC reconfiguration

method focused on reducing weighted structural complexity (WSC) while preserving system efficiency, thereby enhancing adaptability within complex role hierarchies [14]. In a similar vein, Saenko and Kotenko proposed a genetic algorithm-based reconfiguration technique that achieves optimal configurations with notably lower administrative costs than traditional role-mining approaches, especially beneficial in large-scale RBAC systems [15]. Furthermore, Pan et al. highlighted an approach to optimize role-permission assignments in hierarchical RBAC frameworks with minimal system disruption, contributing to the effective management of dynamic permission requirements [16].

To the best of our knowledge, no study has proposed a method for reducing roles in client-specific RBAC systems through reconstruction via clustering while utilizing real-world data and verifying the practical usability of the generated roles. In the study conducted by Rao et al. [17], which aimed to cluster roles, the proposed method was evaluated solely in terms of performance (execution time), with no findings reported regarding the quality or usability of the generated roles.

This paper presents a study aimed at reconfiguring existing RBAC systems by clustering roles based on permission similarities, with the goal of improving the overall performance of the RBAC systems. As part of the study, the researchers collaborated with a medium sized software organization. In the experimental phase, rather than using synthetic data, the study utilized masked data from 10 different clients of the company. Various Python-based libraries were employed for tasks such as data pre-processing, similarity distance measurement, dendrogram extraction based on distance, estimation of the optimal number of clusters using the dendrogram, and the execution of Agglomerative Hierarchical Clustering (AHC), resulting in the creation of role clusters. Finally, the accuracy and adequacy of the results were discussed in detail, and after a long effort in collaboration with experts, the expected clusters were ultimately identified and compared with the clustering outcome, with performance metrics being calculated.

The rest of this paper is organized as follows. Related studies are discussed in Section II. The materials and the detailed approach are given in Section III. In Section IV, presents findings and assessment. Conclusion and future research agenda are discussed in Section V.

II. RELATED WORK

Coyne pioneered the top-down approach and role engineering problem, which involves the analysis of existing business processes and the creation of corresponding roles [6]. To validate the top-down approach in the organizational model, Jin et al. suggested a role-based approach based on event logs [18]. On the other hand, Baumgrass et al. stated that deriving candidate roles from business processes and scenario models is a tedious and challenging operation and proposed to

derive new roles by using UML activity diagrams to automate this operation [19].

The most difficult thing about establishing role-based access control is to come up with complete and accurate list of roles. The challenge of selecting appropriate role groups based on user privileges is defined as Role Mining Problem (RMP) [20]. While most RMP approaches practice the use of permissions with fixed weights, Ma et al. developed a weighted role mining algorithm, which would identify roles by weighting the permissions in a way that correlates to the nature of the transactions or the degree of sensitivity of the objects [21]. Later, Vaidya et al. stated that even if complete and correct set of appropriate roles can be discovered from the existing privileges, there may be significant differences between the roles currently in use and the roles created in the system, so it will not be possible to disable old roles and start using candidate roles at the same time [22]. They presented the Minimal Perturbation RMP approach to produce an ideal role set that considers the problem of deployed roles and replicates existing roles in this direction. Trnecka and Trneckova pointed out that the role mining process is more of an incremental task and proposed an incremental algorithm pointing out that recalculating the roles is inefficient even after slight changes in the data [23].

On the other hand, according to Molloy et al., existing role mining tools do not fully address ways for identifying roles with semantic implications. When the knowledge at hand is a user-privilege relationship, they proposed looking into roles whose meaning is based upon formal concept analysis. Also, they recommend studying roles that may be articulated in user attributes and have a specific meaning when user-specific characteristic information is provided [24]. Vaidya et al. stated that roles are simply matched with a series of privileges when semantics are not available, and unlike the previous approaches, an unsupervised approach based on subset counting the roles having overlapping privileges can be permitted with Role Miner [25].

Pan et al. conducted a study to highlight the fact that the long-term usage of RBAC systems leads to data pollution and this increases the difficulty of managing systems. Organizations can alter their RBAC systems to adapt to changes in departments, employees, and business processes. However, they did mention that it is difficult for such a change not to have any impact on other users and roles. In this case, the system becomes more and more enlarged with new roles defined in the RBAC system. They argued that the RBAC system should be redesigned to minimize the structural complexity of the system and preserve its original functionality. Therefore, they proposed a redesign of the RBAC system to retain its original functionality and reduce its structural complexity [15].

Field studies illustrate bottom-up, top-down, and hybrid approaches to RBAC restructuring, emphasizing efforts to discover candidate roles from existing permissions, optimize RBAC structures, and enhance process efficiency. However, while traditional access control systems have been the

primary focus, cases where overlapping privileges disrupt RBAC functionality present unique challenges, with contemporary research offering limited direction on restructuring RBAC systems by consolidating roles through clustering. Additionally, the literature lacks specific studies targeting the improvement of client-specific RBAC tables. This study, as derived from and an improvement of a thesis work [26], therefore, aims to address this gap by restructuring client-specific RBAC through data preprocessing and data conversion, enabling clustering and grouping roles based on privilege similarity. The study provides guidance on modifying existing roles, clustering newly added roles with compatible pre-existing ones where feasible, and limiting the creation of unnecessary new roles. This approach not only supports the reconfiguration of existing systems tailored to client requirements but also offers foundational guidance on role creation for the design of new RBAC systems.

TABLE 1. Summary of RBAC system data of clients.

File Name	Row Count	URL Count	Role Count	Sector
Client ₁	828	299	28	Automotive
Client ₂	2485	348	36	Automotive
Client ₃	2432	344	31	Automotive
Client ₄	5160	295	68	Food
Client ₅	151	59	14	Food
Client ₆	963	278	44	Food
Client ₇	197	42	28	Food
Client ₈	196	60	14	Food
Client ₉	8112	743	94	Food
Client ₁₀	227	41	19	Food

III. MATERIAL AND METHOD

A. DATASET

Univera, Inc., a software organization with a workforce exceeding 160 employees, including over 40 R&D professionals, provided anonymized data to support this study. With a track record of successfully completing over 130 projects and serving a user base of more than 25,000 mobile users, Univera shared client-specific access control tables from a software product that is actively utilized by multiple clients. This data offers valuable insights into access control dynamics within a live operational environment, enriching the research with real-world applicability.

In recent years, as clients have independently added roles and privileges, maintaining and managing access control data has become increasingly complex. System administrators are tasked with creating and managing new client-specific Role-Based Access Control (RBAC) tables for each client within the software. A masked summary of data from 10 client companies operating in the automotive and food industries is presented in Table 1. Each data table, corresponding to

CLIENT ₁					
C	R	U	D	URL	Role
1	1	1	1	URL ₁	Role ₁
1	1	1	0	URL ₂	Role ₂
1	1	1	1	URL ₄	Role ₁
0	1	0	1	URL ₁	Role ₃
.	.	.	.	.	.
.	.	.	.	.	.

CLIENT ₂					
C	R	U	D	URL	Role
1	1	1	1	URL ₁	Role ₅
1	1	1	1	URL ₂	Role ₆
0	1	1	0	URL ₅	Role ₂
0	1	0	1	URL ₁	Role ₇
.	.	.	.	.	.
.	.	.	.	.	.

FIGURE 1. Sample client-specific RBAC tables.

the clients’ RBAC systems, contains the following attributes for each row: menu number, company code, product number, group code, create-read-update-delete (CRUD) privileges, menu description, target URL, and role name.

The Menu Description column provides a description of the API endpoint and its designation within the system. The URL column specifies the API endpoint, and the Role Name column denotes the name of the role associated with the row. The CRUD columns indicate the permissions with which the role can access the API endpoint listed in the same row and are identified as meaningful columns for the clustering process.

The Row Count column in the table indicates the total number of rows independently managed by each client company. The URL Count column represents the total number of unique API endpoints in each table, while the Role Count column shows the total number of unique roles in each table. The number of roles may vary depending on the size of the client company and management capabilities. In fact, the number of roles for the Client₉ has increased to 94 over time, while the number of roles for the Client₅ and Client₈ are 14. On the other hand, since each company manages its own RBAC system independently, the rows in the RBAC tables can vary significantly between companies. For example, the highest authority role in one company may be labeled as “admin” (e.g., Role₁) whereas in another company, it may be designated as “central” (e.g., Role₅) (Fig. 1). Each company

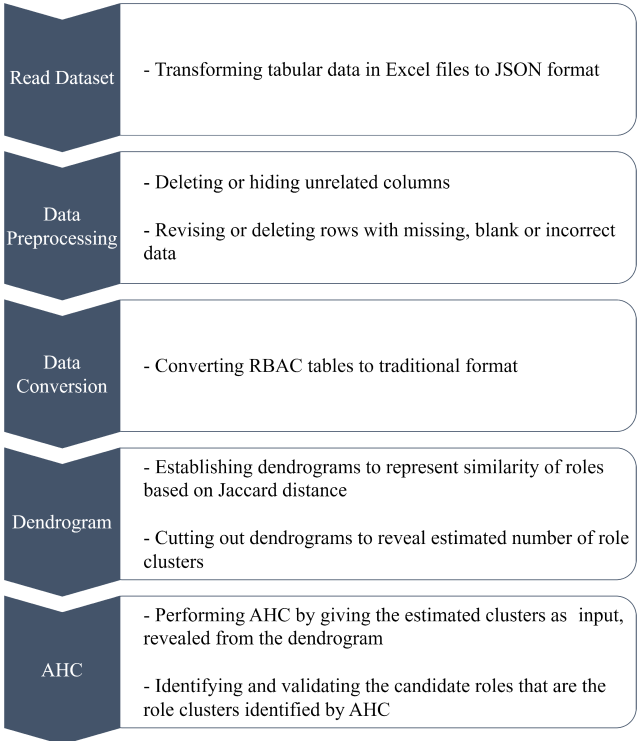


FIGURE 2. Steps of the approach.

is authorized to access URLs corresponding to specific sections of the system and can define roles and permissions accordingly.

B. METHOD

The approach used in this study aimed to reach a limited role set to be used in reconfiguring the system. AHC is one of the most traditional, popular, and unsupervised clustering algorithm [27], and represents the bottom-up approach from hierarchical clustering algorithms [28]. It treats each element in the data set as a cluster and combines these clusters sequentially to eventually obtain a single cluster. Since the approach is a bottom-up approach and therefore the most suitable algorithm for the approach, AHC was used in the clustering phase. A flow diagram of the approach is shown in Fig. 2.

An analysis was carried out on the RBAC-based dataset provided by the company. To gain a deeper understanding of the data and its implications, negotiations were held with the company’s R&D unit over a period of 10 weeks, with sessions occurring once a week for 2 hours each.

The software is used by clients that own licenses for the system. The ten RBAC-based tables are the role-privilege assignments used by the client companies. In the columns of the tables, there are menu number, company code, product number, group code, CRUD privileges, menu description, target API endpoint URL, and role name. The columns that fully determine the authority of the roles in the rows of the tables are the URL and CRUD columns. But the URL is

the most prominent column in the definition of the role's privileges. Because when there is no URL column, only read, write, update, and delete privileges of the role remain, while it is not known which page or API endpoint these privileges target. When there is only the URL column, even if the roles do not have privileges, at least the role's target becomes clear, only the information that limits its behavior on that target disappears. However, when only the URL column is used reckon without the CRUD privileges, the roles that can operate on the same URL but with completely different operation privileges looking similar to each other. In addition, because the same role can reach different URL targets with different privileges in the presented table structures, the same role can exist in more than one row in the same table with different privileges. Considering these, it has been determined that the RBAC tables presented were created far from widespread use and would cause difficulties in applying the approach without data pre-processing.

First, permission-role table files containing the access control data were read with the Python-based xldr library, data preprocessing was done during data reading, and the data were recorded in dictionary type in the JSON format. First of all, the data was preprocessed. In the first stage of preprocessing, the columns not containing URL, role name, and CRUD privileges were deleted because they did not contain meaningful and useful information for the solution of the problem. In addition, in line with the guidance of company experts, rows containing that has missing data points or contains legacy page URLs were detected and deleted in order not to adversely affect the performance or evaluation of the clustering algorithm. The data set which has been processed to contain only important and usable data for the clustering algorithm, has been converted to JSON format because it is easy to work with unique values and is an easy structure to read, write, create, and parse [29]. In the final dataset, only privileges that are dependent on URLs, also roles, and URLs for each role are available.

After deleting the rows and columns of data that were detected to be unnecessary and after a walkthrough on the dataset for ensuring that the role definitions are meaningful with the collaboration of the company experts, data conversion was performed. In the data conversion stage, the tables presented for each client have converted to a format similar to traditional access control systems, as they were not in a clustering format, thus making them suitable for clustering. The conversion is shown in Fig. 3 with completely randomly generated data that does not represent real permissions. Before converting the table structure, each role could exist in a different number of rows. After converting, each role has been made obtainable on only one row and the total number of URLs times 4 columns (i.e., CRUD columns) for each role are created.

The dendrogram extraction by calculating the Jaccard distances from the row data obtained after reading the files was done using the SciPy library. The Jaccard index, or distance, which is one of the most widely used and

C	R	U	D	URL	Role
1	1	1	1	URL ₁	Role ₁
1	1	1	0	URL ₂	Role ₂
0	1	0	0	URL ₂	Role ₁
0	1	0	1	URL ₁	Role ₃
·	·	·	·	·	·
·	·	·	·	·	·

Role	URL ₁				URL ₂				...	URL _n			
	C	R	U	D	C	R	U	D		C	R	U	D
Role ₁	1	1	1	1	0	1	0	0	...	0	0	0	0
Role ₂	0	0	0	0	1	1	1	0	...	0	0	0	0
Role ₃	0	1	0	1	0	0	0	0	...	0	1	0	0
...	·	·	·	·	·	·	·	·	...	·	·	·	·
Role _n	0	1	0	0	0	1	0	0	...	1	1	1	1

FIGURE 3. Data conversion: client specific RBAC to traditional RBAC.

effective indices among similarity indices employed for binary data [30], is advantageous as a distance metric due to its ease of application and speed in generating results [31]. In the approach, the Jaccard distance was used to find similarities between the roles. Here, the similarity calculation is done between roles, and the similarity criteria were chosen as the target URLs' CRUD privileges associated with each role. The dendrogram output is a tree graphical representation of the cross-role similarity, and the dendrogram output was obtained using the matplotlib library.

Fig. 4 shows the dendrogram extracted for Client₂, that is the client company (i.e. one of the 10 clients) whose graphs are presented throughout this paper for illustration purposes. The horizontal axis represents the roles uniquely defined in the table. The vertical axis of the dendrogram indicates the Jaccard distance between the roles and takes a value between 0 and 1.

The more similar the two roles are, the shorter the vertical axis length of the connecting line and the smaller the Jaccard distance between them. If two roles are slightly similar, the Jaccard distance between them is large, so the connecting line between the two roles is longer on the vertical axis. If two roles are exactly alike, the distance between them is 0, and the length of the connecting line of roles on the vertical axis is 0. Similarly, if the privileges of two roles are completely different, the Jaccard distance between them and the vertical length of the line connecting the roles are equal to 1.

The Jaccard index is a criterion that can be used to find similarities in clusters or binary data, which has practical applications in information retrieval, machine learning, data mining, and many other subjects and applications [32]. For two binary data A and B, Jaccard index is defined as shown in (1) below:

$$J(A, B) = \frac{|A \cap B|}{|A \cup B|} \quad (1)$$

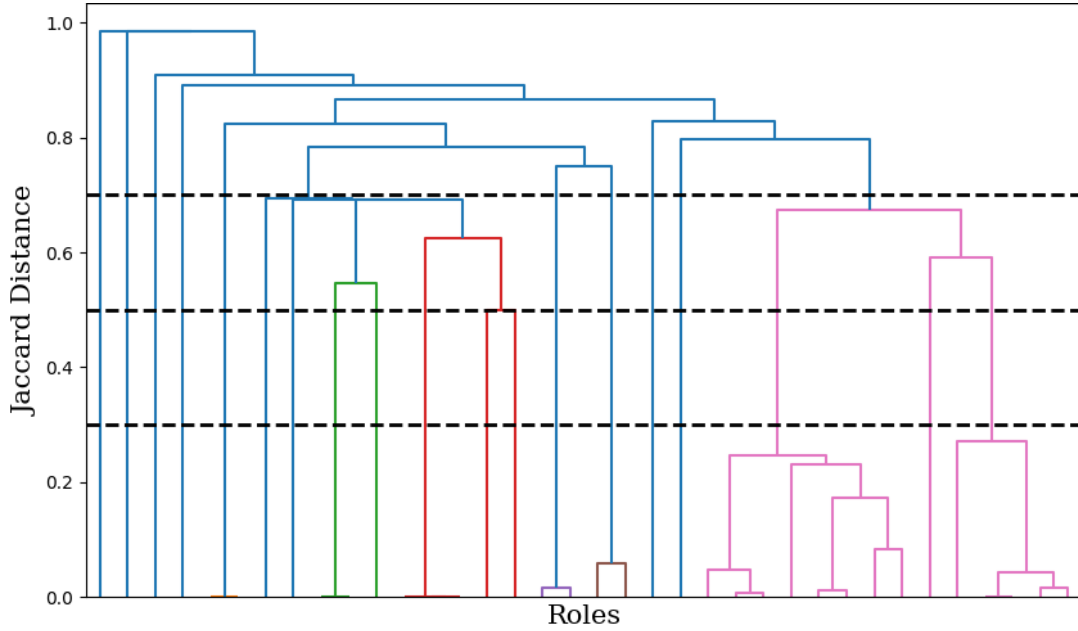


FIGURE 4. Threshold value set at 0.3, 0.5, and 0.7 on dendrogram for Client₂.

Jaccard distance used in creating the dendrogram is the complement of Jaccard index to 1 and is shown in (2):

$$J_d(A, B) = 1 - \frac{|A \cap B|}{|A \cup B|} \quad (2)$$

A dendrogram's cutoff value is determined by the number of points on the vertical axis intersecting the horizontal axis' threshold line. This determines the number of clusters formed by this value. Some threshold values were applied to dendrograms to determine the number of role clusters that will be used in Agglomerative Hierarchical Clustering [33]. There is no agreement about the most ideal cut for setting a threshold value on the dendrogram and the threshold value setting is done intuitively [34]. This approach was repeated with cut-off values decremented by 0.1 between the values ranging from 0.7 to 0.1.

After determining the threshold value through dendrograms and estimating the number of role clusters, the Agglomerative Hierarchical Clustering algorithm was applied to all clients by using the Python-based scikit-learn library. Client₂, having 36 roles (a mid-range number), is selected for example purposes.

In the dendrogram of Client₂ shown in Fig. 4, three threshold values (0.3, 0.5 and 0.7) were determined for illustrative purposes only. When the cut-off point in the dendrogram is set according to the Jaccard distance between the roles to be 0.7, the expected number of clusters is 11, as seen in the dendrogram and Fig. 5. With applying the threshold value of 0.5, 15 clusters could be formed (Fig. 6) and with threshold value of 0.3, 18 clusters of roles are observed to form (Fig. 7). Only for the 0.3, 0.5, and 0.7 cut-off points, the resulting role clusters and the role count they contain were shown in Fig. 8.

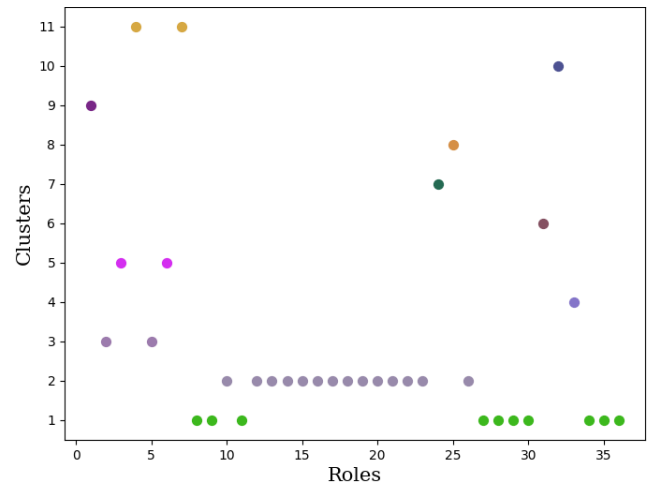


FIGURE 5. AHC result for threshold point on 0.7.

As expected, more role clusters form when the threshold values are kept low on the dendrogram. However, in those cases, the roles in the clusters were more similar to each other, so more cohesive clusters are formed. On the other hand, when the threshold values are kept high on the dendrogram, fewer clusters are formed with less similar roles in each of them.

C. EVALUATION

The dendrogram of the client data tables was extracted and the clustering was performed for each table with threshold values decremented by 0.1 between the values ranging from 0.7 to 0.1. The role clusters obtained as a result of the clustering were compared with the gold standard (actually expected role clusters prepared by the experts in the R&D unit of the

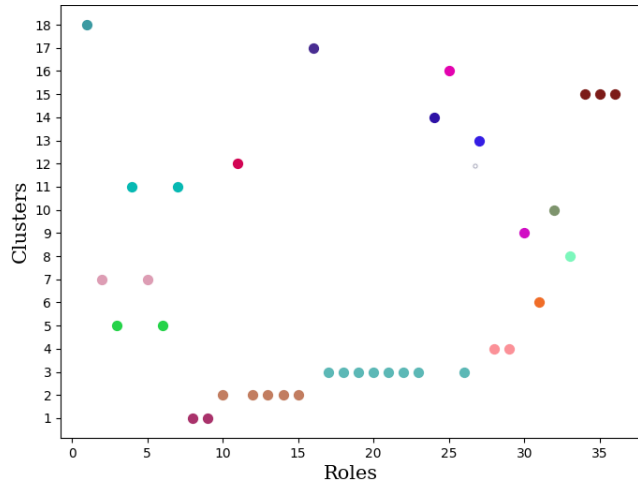


FIGURE 6. AHC result for threshold point on 0.5.

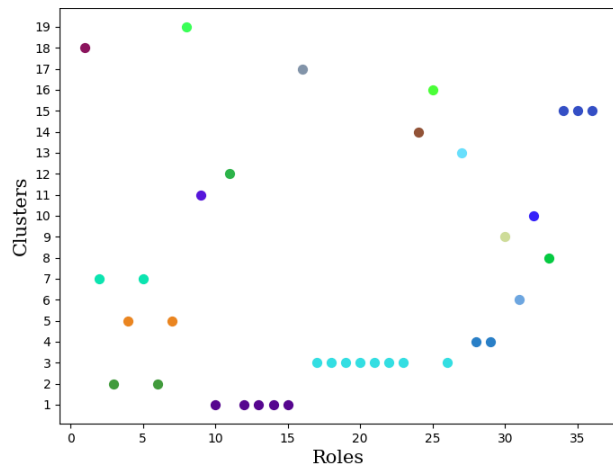


FIGURE 7. AHC result for threshold point on 0.3.

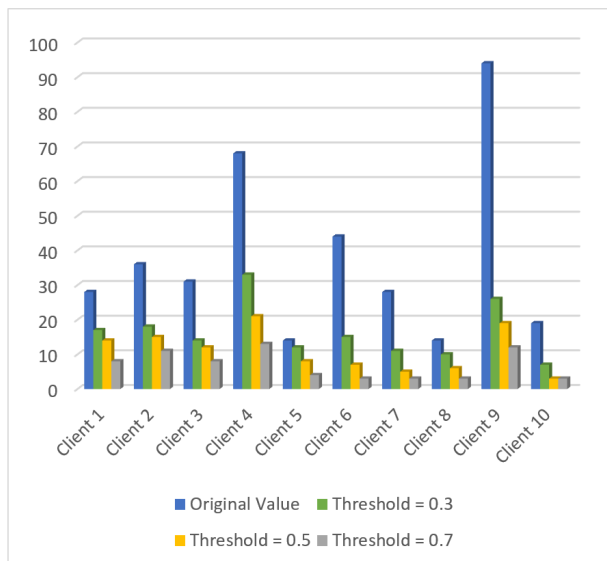


FIGURE 8. Number of created roles and role clusters by using different threshold values for each client data.

software company) [35] in other words ground truth (gT) data [36].

- RPPC = Role pairs in predicted clusters.
- RPGC = Role pairs in gT clusters.

$$pP = \frac{|RPPC \cap RPGC|}{|RPPC|} \quad (3)$$

$$pR = \frac{|RPPC \cap RPGC|}{|RPGC|} \quad (4)$$

$$pF1 = \frac{|2 \times pP \times pR|}{|pP + pR|} \quad (5)$$

Pairwise precision (pP), pairwise recall (pR), and pairwise f1 score (pF1) values [37], [38] were calculated for each client for each threshold value (Table 2). Equation (3), (4), (5) show how to calculate pP, pR and pF1 respectively. When a role in a gT cluster was not in the same gT cluster with other roles (negative - N), and the same role was not in the same cluster with other roles (true negative - TN) in predicted clusters, the TN value is unevenly counted high compared to the other values. Because pairwise comparison was used to evaluate, a role produces one true positive (TP) value for a role it was in the same cluster and more TN values for each role it is not in the same cluster. In this case, the accuracy values are not included in the table because they are likely to produce misleading results [39], [40]. The formula for how the comparison metrics were calculated and the abbreviations used in the formula are shown above.

IV. RESULTS

An experimental study was performed on the access control system data of a software company, using ten data tables, each of which contains RBAC system data from a different client. Only the results of the second client data analysis were presented graphically in the previous section as an example.

In the experiment, which was performed by making dendrogram cut-offs with values starting from 0.7 and decreasing by 0.1. As the cut-off value increased, it was observed that the role clusters formed were less similar to each other, but the number of clusters decreased. As the dendrogram cut-off value gets closer to 0.1, it has been observed that the roles assigned to the same cluster are much more similar to each other, but the number of clusters formed is higher.

When the pairwise f1 score values obtained were analyzed with the participation of the experts in the R&D unit of the software company, it was seen that the new candidate roles consist of roles that are more similar to each other and generally more compatible when the threshold value selected for dendrograms is less than 0.6. It is noteworthy that as the threshold value selected for the dendrogram cutoff increases, especially after exceeding the value of 0.6, the accuracy of the candidate roles significantly decreases in this study.

As shown in Table 2, pP and pF1 values generally have the highest values at points lower than the 0.4 threshold value, while the pR values generally have the highest values at points when the threshold value was higher than 0.5. This is because Recall values show how well positive situations are predicted, on the other hand, Precision values show positively

TABLE 2. Evaluation results for different metrics for each client.

Clients	Metrics	Threshold Values						
		0.1	0.2	0.3	0.4	0.5	0.6	0.7
Client ₁	pP	1.00	1.00	1.00	0.90	0.73	0.66	0.35
	pR	0.58	0.84	0.95	0.95	1.00	1.00	1.00
	pF1	0.73	0.91	0.97	0.92	0.84	0.79	0.51
Client ₂	pP	1.00	1.00	0.58	0.58	0.59	0.51	0.21
	pR	0.60	0.73	0.87	0.87	0.90	0.90	0.97
	pF1	0.75	0.85	0.69	0.69	0.71	0.65	0.34
Client ₃	pP	1.00	1.00	0.64	0.64	0.65	0.59	0.27
	pR	0.57	0.70	0.93	0.97	1.00	1.00	1.00
	pF1	0.72	0.82	0.76	0.77	0.79	0.74	0.43
Client ₄	pP	0.75	0.79	0.83	0.52	0.30	0.14	0.08
	pR	0.57	0.70	0.91	0.94	0.96	1.00	1.00
	pF1	0.65	0.75	0.87	0.67	0.46	0.24	0.15
Client ₅	pP	1.00	1.00	1.00	1.00	0.50	0.18	0.04
	pR	1.00	1.00	1.00	1.00	1.00	1.00	1.00
	pF1	1.00	1.00	1.00	1.00	0.67	0.31	0.09
Client ₆	pP	1.00	1.00	0.58	0.55	0.46	0.44	0.22
	pR	0.39	0.57	0.65	0.88	0.99	0.99	0.99
	pF1	0.56	0.73	0.62	0.68	0.63	0.61	0.35
Client ₇	pP	1.00	1.00	1.00	1.00	0.68	0.68	0.32
	pR	0.47	0.55	0.76	0.88	1.00	1.00	1.00
	pF1	0.64	0.71	0.87	0.93	0.81	0.81	0.48
Client ₈	pP	1.00	1.00	1.00	1.00	1.00	0.41	0.35
	pR	0.09	0.36	0.45	1.00	1.00	1.00	1.00
	pF1	0.17	0.53	0.63	1.00	1.00	0.58	0.52
Client ₉	pP	0.81	0.77	0.76	0.68	0.50	0.40	0.35
	pR	0.99	0.99	1.00	1.00	1.00	1.00	1.00
	pF1	0.89	0.87	0.86	0.81	0.67	0.57	0.52
Client ₁₀	pP	1.00	0.62	0.65	0.65	0.66	0.46	0.39
	pR	0.33	0.74	0.96	0.96	1.00	1.00	1.00
	pF1	0.50	0.68	0.78	0.78	0.79	0.63	0.56

predicted situations how successfully [41]. As the Threshold value increases, the clusters contain less similar roles, thus increasing the number of incorrectly positive predicted values (false positive - FP). Thus, the Precision value decreases as the threshold value increases. On the contrary, as the threshold value increases, the Recall value increases, because decreasing the number of incorrectly negative predicted values. Because as the threshold value increases, less similar roles were placed in the same cluster by the algorithm, in a word the number of negative predictions decreases. These highest values are highlighted in Table 2 for each client. As is seen in Table 2, the algorithm produced ideal expected role sets for some clients when applied some threshold values. In line with the walkthroughs with the company experts, it has been observed that the pF1 values are highly consistent with the expected results.

V. CONCLUSION AND FUTURE WORK

In this study, Agglomerative Hierarchical Clustering (AHC) was applied to the client-specific Role-Based Access Control (RBAC) system data of 10 different clients of a software company. The research aimed to investigate whether the role clusters obtained through AHC using Jaccard distance and various threshold values could be used as new candidate roles for enhancing existing RBAC systems.

Although Agglomerative Hierarchical Clustering (AHC) has been employed for various purposes, such as classifying daily load curves of households based on consumption patterns [42], identifying vulnerable lines in smart grid systems [43], analyzing the distribution of urban road traffic noise [44], examining anthropogenic factors in Indonesian aviation accidents [45], assessing elemental affinities in coal [46], and estimating genetic differences in wheat genotypes based on agro-morphological traits [47]. A single study utilized AHC for role mining [14], yet its primarily focus was on evaluating the performance of the method rather than assessing the usability of the roles derived from clustering.

When the results were examined in collaboration with the experts from the software company's R&D unit, it was observed that as the selected threshold value for the dendrogram decreased, the new candidate roles were more similar to each other and generally more useful. However, this also resulted in a higher number of candidate roles being formed. Conversely, as the threshold value increased, the number of candidate roles decreased; however, the roles created tended to be less useful due to the clustering of less similar roles. Although some results obtained at certain threshold values aligned exactly with the expected output, a clear conclusion regarding the availability of a single optimal threshold value could not be established.

Therefore, identifying the optimal threshold value when applying this approach, which could serve as a guideline for developing RBAC systems, appears to require a combination of intuition and domain expertise.

Aligned with this approach, the analysis revealed that users cannot directly adopt the new candidate roles formed by clustering previous roles within the system's current configuration. As a result, company experts determined that the candidate roles generated are unsuitable for directly replacing roles in an existing RBAC system. However, the findings offer valuable insights, supporting decision-making processes related to roles and privileges when designing a new RBAC system or enhancing outdated configurations. Additionally, the study, which analyzed RBAC tables from clients across two distinct industries, illustrates that the approach applies effectively to data from diverse sectors, indicating its potential for broader generalization.

Moreover, for the clustering approach to yield optimal and consistent results, it is crucial that roles are accurately and thoroughly defined. Issues such as defining the highest-privileged role (e.g., admin) in a client without certain permissions (i.e. failing to truly function as the most authoritative role) or granting permissions that are exclusively reserved for the highest-privileged role in some clients to non-privileged users in others may lead to the clustering approach not performing as expected. Furthermore, once the clusters are identified, a domain expert involved mapping between the derived clusters and real-world business roles is essential.

Future studies will explore various distance metrics and linkage methods to assess their impact, effectiveness, and their potential in terms of optimization in accurately identifying role clusters during the RBAC system clustering phase, while incorporating the Silhouette Score and Davies-Bouldin Index metrics to evaluate cluster cohesion and separation. Future work agenda includes improving the accuracy of this approach by integrating industry-specific insights from clients across diverse industries, as well as measuring the performance improvement of the RBAC systems after the reconfiguration method applied as proposed in this study. Furthermore, the literature currently lacks a straightforward, universally applicable validation method for clustering algorithms, likely due to inconsistencies between the expected cluster count and object distribution within expected clusters versus those generated by the algorithm. Since exact matching is not feasible for comparing these results, further research can focus on refining existing validation methods or developing innovative approaches for validating clustering algorithms more effectively.

ACKNOWLEDGMENT

The authors would like to express their gratitude to Onur Leblebici, Barış Özyer, and Onur Demirörs for providing their valuable feedback and suggestions to this manuscript. They also would like to thank Univera Inc. (www.univera.com.tr) for granting them access for using their data in this study.

This work is derived from Osman Durdag's Master's thesis, completed at Atatürk University under the supervision of Ahmet Coskuncay.

REFERENCES

- [1] Z. Yang, L. Yang, X.-Y. Luo, L.-R. Ma, B.-S. Kou, and K. Zhang, "Model of domain based RBAC and supporting technologies," *J. Comput.*, vol. 8, no. 5, pp. 1220–1229, May 2013, doi: [10.4304/jcp.8.5.1220-1229](https://doi.org/10.4304/jcp.8.5.1220-1229).
- [2] M. A. C. Dekker, J. M. Crampton, and S. Etalle, "RBAC administration in distributed systems," in *Proc. 13th ACM Symp. Access Control Models Technol. (SACMAT)*, Jun. 2008, pp. 93–102, doi: [10.1145/1377836.1377852](https://doi.org/10.1145/1377836.1377852).
- [3] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, and C. E. Youman, "Role-based access control models," *Computer*, vol. 29, no. 2, pp. 38–47, Feb. 1996, doi: [10.1109/2.485845](https://doi.org/10.1109/2.485845).
- [4] M. Gallaher, A. O'Connor, B. Kropp, and G. Tassey, "The economic impact of role-based access control," Nat. Inst. Stand. Technol., Gaithersburg, MD, USA, Tech. Rep. 02-1, 2002.
- [5] B. Liu, A. Michalas, and B. Warinschi, "Cryptographic role-based access control, reconsidered," in *Provable and Practical Security (PROVSEC)*, vol. 13600, C. Ge and F. Guo, Eds., Cham, Switzerland: Springer, 2022, pp. 282–289, doi: [10.1007/978-3-031-20917-8_19](https://doi.org/10.1007/978-3-031-20917-8_19).
- [6] E. J. Coyne, "Role engineering," in *Proc. 1st ACM Workshop Role-Based Access Control (RBAC)*, Jan. 1996, pp. 4–10.
- [7] E. J. Coyne, T. R. Weil, and R. Kuhn, "Role engineering: Methods and standards," *IT Prof.*, vol. 13, no. 6, pp. 54–57, Nov. 2011, doi: [10.1109/MITP.2011.105](https://doi.org/10.1109/MITP.2011.105).
- [8] M. Frank, J. M. Buhmann, and D. Basin, "On the definition of role mining," in *Proc. 15th ACM Symp. Access Control Models Technol. (SACMAT)*, Jun. 2010, pp. 35–44, doi: [10.1145/1809842.1809851](https://doi.org/10.1145/1809842.1809851).
- [9] W. Sun, H. Su, and H. Liu, "Role-engineering optimization with cardinality constraints and user-oriented mutually exclusive constraints," *Information*, vol. 10, no. 11, p. 342, Nov. 2019, doi: [10.3390/info10110342](https://doi.org/10.3390/info10110342).
- [10] I. Molloy, H. Chen, T. Li, Q. Wang, N. Li, E. Bertino, S. Calo, and J. Lobo, "Mining roles with multiple objectives," *ACM Trans. Inf. Syst. Secur.*, vol. 13, no. 4, pp. 1–35, Dec. 2010, doi: [10.1145/1880022.1880030](https://doi.org/10.1145/1880022.1880030).
- [11] O. Leblebici, G. Kardas, and T. Tuglular, "A domain-specific language for the document-based model-driven engineering of business applications," *IEEE Access*, vol. 10, pp. 104093–104110, 2022, doi: [10.1109/ACCESS.2022.3210530](https://doi.org/10.1109/ACCESS.2022.3210530).
- [12] E. Bertino, S. Calo, H. Chen, N. Li, T. Li, J. Lobo, I. Molloy, and Q. Wang, "Some usability considerations in access control systems," in *Proc. Workshop on Usable IT Secur. Manage. (USM), Symp. Usable Privacy Secur. (SOUPS)*, Pittsburgh, PA, USA, Jul. 2008. [Online]. Available: cups.cs.cmu.edu/soups/2008/USM/bertino.pdf
- [13] I. Saenko and I. Kutenko, "Adminstrating role-based access control by genetic algorithms," in *Proc. Genetic Evol. Comput. Conf. Companion*, Jul. 2017, pp. 1463–1470, doi: [10.1145/3067695.3082509](https://doi.org/10.1145/3067695.3082509).
- [14] N. Pan, L. Sun, L.-S. He, and Z.-Q. Zhu, "An approach for hierarchical RBAC reconfiguration with minimal perturbation," *IEEE Access*, vol. 6, pp. 40389–40399, 2018, doi: [10.1109/ACCESS.2017.2782838](https://doi.org/10.1109/ACCESS.2017.2782838).
- [15] I. Saenko and I. Kutenko, "Reconfiguration of RBAC schemes by genetic algorithms," in *Intelligent Distributed Computing X (IDC 2016)* (Studies in Computational Intelligence), vol. 678, C. Bădică et al., Eds., Cham, Switzerland: Springer, 2017, pp. 89–98, doi: [10.1007/978-3-319-48829-5_9](https://doi.org/10.1007/978-3-319-48829-5_9).
- [16] N. Pan, Z. Zhu, L. He, and L. Sun, "An efficiency approach for RBAC reconfiguration with minimal roles and perturbation," *Concurrency Comput., Pract. Exper.*, vol. 30, no. 11, Jun. 2018, Art. no. e4399, doi: [10.1002/cpe.4399](https://doi.org/10.1002/cpe.4399).
- [17] K. R. Rao, A. Kolpe, T. Pradhan, and B. B. Zarpelão, "An efficient solution to user authorization query problem in RBAC systems using hierarchical clustering," *J. Cyber Secur. Mobility*, vol. 11, no. 4, pp. 531–548, Nov. 2022, doi: [10.13052/jcsm2245-1439.1142](https://doi.org/10.13052/jcsm2245-1439.1142).
- [18] T. Jin, J. Wang, and L. Wen, "Organizational modeling from event logs," in *Proc. 6th Int. Conf. Grid Cooperat. Comput. (GCC)*, Aug. 2007, pp. 670–675, doi: [10.1109/gcc.2007.93](https://doi.org/10.1109/gcc.2007.93).
- [19] A. Baumgrass, M. Strembeck, and S. Rinderle-Ma, "Deriving role engineering artifacts from business processes and scenario models," in *Proc. 16th ACM Symp. Access Control Models Technol.*, Jun. 2011, pp. 11–20, doi: [10.1145/1998441.1998445](https://doi.org/10.1145/1998441.1998445).

- [20] J. Vaidya, V. Atluri, and Q. Guo, "The role mining problem: Finding a minimal descriptive set of roles," in *Proc. 12th ACM Symp. Access Control Models Technol. (SACMAT)*, Oct. 2007, pp. 175–184, doi: [10.1145/1266840.1266870](https://doi.org/10.1145/1266840.1266870).
- [21] X. Ma, R. Li, and Z. Lu, "Role mining based on weights," in *Proc. 15th ACM Symp. Access Control Models Technol.*, Jun. 2010, pp. 65–74, doi: [10.1145/1809842.1809854](https://doi.org/10.1145/1809842.1809854).
- [22] J. Vaidya, V. Atluri, Q. Guo, and N. R. Adam, "Migrating to optimal RBAC with minimal perturbation," in *Proc. 13th ACM Symp. Access Control Models Technol. (SACMAT)*, Jun. 2008, pp. 11–20, doi: [10.1145/1377836.1377839](https://doi.org/10.1145/1377836.1377839).
- [23] M. Trnecka and M. Trneckova, "An incremental algorithm for the role mining problem," *Comput. Secur.*, vol. 94, Jul. 2020, Art. no. 101830, doi: [10.1016/j.cose.2020.101830](https://doi.org/10.1016/j.cose.2020.101830).
- [24] I. Molloy, H. Chen, T. Li, Q. Wang, N. Li, E. Bertino, S. Calo, and J. Lobo, "Mining roles with semantic meanings," in *Proc. 13th ACM Symp. Access Control Models Technol. (SACMAT)*, Jun. 2008, pp. 21–30, doi: [10.1145/1377836.1377840](https://doi.org/10.1145/1377836.1377840).
- [25] J. Vaidya, V. Atluri, J. Warner, and Q. Guo, "Role engineering via prioritized subset enumeration," *IEEE Trans. Dependable Secure Comput.*, vol. 7, no. 3, pp. 300–314, Jul. 2010, doi: [10.1109/TDSC.2008.61](https://doi.org/10.1109/TDSC.2008.61).
- [26] O. Durdag, "Reconfiguring role-based access control systems by using AHC in role mining: A software industry experience," M.S. thesis, Dept. Comput. Eng., Ataturk Univ., Erzurum, Turkey, 2023.
- [27] N. Liu, Z. Xu, X.-J. Zeng, and P. Ren, "An agglomerative hierarchical clustering algorithm for linear ordinal rankings," *Inf. Sci.*, vol. 557, pp. 170–193, May 2021, doi: [10.1016/j.ins.2020.12.056](https://doi.org/10.1016/j.ins.2020.12.056).
- [28] M. Jafarzadegan, F. Safi-Esfahani, and Z. Beheshti, "An agglomerative hierarchical clustering framework for improving the ensemble clustering process," *Cybern. Syst.*, vol. 53, no. 8, pp. 679–701, Nov. 2022, doi: [10.1080/01969722.2022.2042917](https://doi.org/10.1080/01969722.2022.2042917).
- [29] B. Lin, Y. Chen, X. Chen, and Y. Yu, "Comparison between JSON and XML in applications based on AJAX," in *Proc. Int. Conf. Comput. Sci. Service Syst.*, Aug. 2012, pp. 1174–1177, doi: [10.1109/CSSS.2012.297](https://doi.org/10.1109/CSSS.2012.297).
- [30] P. N. Tan, M. Steinbach, and V. Kumar, "Cluster analysis: Basic concepts and algorithms," in *Introduction to Data Mining*. Boston, MA, USA: Addison-Wesley, 2005, pp. 487–568.
- [31] N. A. A. Aziz, S. S. Salleh, D. Mohamad, and M. Omar, "Investigating Jaccard distance similarity measurement constriction on handwritten pen-based input digit," in *Proc. Int. Conf. Sci. Social Res. (CSSR)*, Dec. 2010, pp. 1181–1185, doi: [10.1109/CSSR.2010.5773712](https://doi.org/10.1109/CSSR.2010.5773712).
- [32] S. Kosub, "A note on the triangle inequality for the Jaccard distance," *Pattern Recognit. Lett.*, vol. 120, pp. 36–38, Apr. 2019, doi: [10.1016/j.patrec.2018.12.007](https://doi.org/10.1016/j.patrec.2018.12.007).
- [33] V. Van Hai, H. L. L. Nhung, and R. Jasek, "Toward applying agglomerative hierarchical clustering in improving the software development effort estimation," in *Software Engineering Perspectives in Systems* (Lecture Notes in Networks and Systems), vol. 501, R. Silhavy, Ed., Cham, Switzerland: Springer, 2022, pp. 353–371, doi: [10.1007/978-3-031-09070-7_30](https://doi.org/10.1007/978-3-031-09070-7_30).
- [34] C. Li and G. Biswas, "Unsupervised learning with mixed numeric and nominal data," *IEEE Trans. Knowl. Data Eng.*, vol. 14, no. 4, pp. 673–690, Jul. 2002, doi: [10.1109/TKDE.2002.1019208](https://doi.org/10.1109/TKDE.2002.1019208).
- [35] G. Palma, M.-E. Vidal, E. Haag, L. Raschid, and A. Thor, "Determining similarity of scientific entities in annotation datasets," *Database*, vol. 2015, Jan. 2015, Art. no. bau123, doi: [10.1093/database/bau123](https://doi.org/10.1093/database/bau123).
- [36] M. Aklin, P. Bayer, S. P. Harish, and J. Urpelainen, "Preface," in *Escaping the Energy Poverty Trap: When and How Governments Power the Lives of the Poor*. Dordrecht, The Netherlands: Springer, 2018, pp. 5–7.
- [37] J. Kim, J. Kim, and J. Owen-Smith, "Generating automatically labeled data for author name disambiguation: An iterative clustering method," *Scientometrics*, vol. 118, no. 1, pp. 253–280, Jan. 2019, doi: [10.1007/s11192-018-2968-3](https://doi.org/10.1007/s11192-018-2968-3).
- [38] J. Kim, "A fast and integrative algorithm for clustering performance evaluation in author name disambiguation," *Scientometrics*, vol. 120, no. 2, pp. 661–681, Aug. 2019, doi: [10.1007/s11192-019-03143-7](https://doi.org/10.1007/s11192-019-03143-7).
- [39] J. P. Mower, "PREP-mt: Predictive RNA editor for plant mitochondrial genes," *BMC Bioinf.*, vol. 6, no. 1, Apr. 2005, Art. no. 96, doi: [10.1186/1471-2105-6-96](https://doi.org/10.1186/1471-2105-6-96).
- [40] P. Kanani and A. McCallum, "Efficient strategies for improving partitioning-based author coreference by incorporating web pages as graph nodes," in *Proc. Workshop Inf. Integr. Web (IIWeb)*, Jan. 2007, pp. 38–43.
- [41] T. Fawcett, "An introduction to ROC analysis," *Pattern Recognit. Lett.*, vol. 27, no. 8, pp. 861–874, Jun. 2006, doi: [10.1016/j.patrec.2005.10.010](https://doi.org/10.1016/j.patrec.2005.10.010).
- [42] F. AlMahamid and K. Grolinger, "Agglomerative hierarchical clustering with dynamic time warping for household load curve clustering," in *Proc. IEEE Can. Conf. Electr. Comput. Eng. (CCECE)*, Sep. 2022, pp. 241–247, doi: [10.1109/CCECE49351.2022.9918481](https://doi.org/10.1109/CCECE49351.2022.9918481).
- [43] L. Yang and C. Li, "Identification of vulnerable lines in smart grid systems based on improved agglomerative hierarchical clustering," *IEEE Access*, vol. 11, pp. 13554–13563, 2023, doi: [10.1109/ACCESS.2023.3243806](https://doi.org/10.1109/ACCESS.2023.3243806).
- [44] A. E. Forouhid, S. Khosravi, and J. Mahmoudi, "Noise pollution analysis using geographic information system, agglomerative hierarchical clustering and principal component analysis in Urban sustainability (case study: Tehran)," *Sustainability*, vol. 15, no. 3, Feb. 2023, Art. no. 2112, doi: [10.3390/su15032112](https://doi.org/10.3390/su15032112).
- [45] R. Passarella, G. Oktariani, D. Kurniawan, and P. Sari, "Using the agglomerative hierarchical clustering method to examine human factors in Indonesian aviation accidents," *Int. J. Adv. Comput. Sci. Appl.*, vol. 13, no. 9, pp. 325–331, Sep. 2022, doi: [10.14569/ijacsa.2022.0130938](https://doi.org/10.14569/ijacsa.2022.0130938).
- [46] M. Eminagaoglu, R. G. Oskay, and A. I. Karayigit, "Evaluation of elemental affinities in coal using agglomerative hierarchical clustering algorithm: A case study in a thick and mineable coal seam (km²) from soma basin (W. Turkey)," *Int. J. Coal Geol.*, vol. 259, Jul. 2022, Art. no. 104045, doi: [10.1016/j.coal.2022.104045](https://doi.org/10.1016/j.coal.2022.104045).
- [47] A. Khalid, A. Hameed, and M. F. Tahir, "Estimation of genetic divergence in wheat genotypes based on agro-morphological traits through agglomerative hierarchical clustering and principal component analysis," *Cereal Res. Commun.*, vol. 51, no. 1, pp. 217–224, Mar. 2023, doi: [10.1007/s42976-022-00287-w](https://doi.org/10.1007/s42976-022-00287-w).



OSMAN DURDAG received the B.S. degree in computer engineering from Karadeniz Technical University, Trabzon, in 2019, and the M.S. degree in computer engineering from Atatürk University, Erzurum, Türkiye, in 2023, where he is currently pursuing the Ph.D. degree with the Computer Engineering Department. He has been a Research Assistant with the Software Engineering Department, Atatürk University, since 2021. His research interests include data mining, artificial neural networks, and image processing.



AHMET COSKUNCAY is currently an Assistant Professor with the Computer Engineering Department, Atatürk University, Türkiye. As a Ph.D. Holder in information systems from Middle East Technical University, he teaches and researches in software engineering. He has been actively participating in many private sector projects as a Software Engineering Researcher and a Consultant. His research interests include empirical software engineering, business process management, ontology engineering, and machine learning.

...